



Coding for Compliance Without Losing Your Mind:

Real-world CRA and RED DA Lessons

Derek Yu

OWASP Switzerland Community Event | 2025-06-17

CE

Takeaway cheat sheet: what companies need to do for CRA

List products affected by CRA:

- Regular products → Article 3
- Important products → Annex III
- Critical products → Annex IV

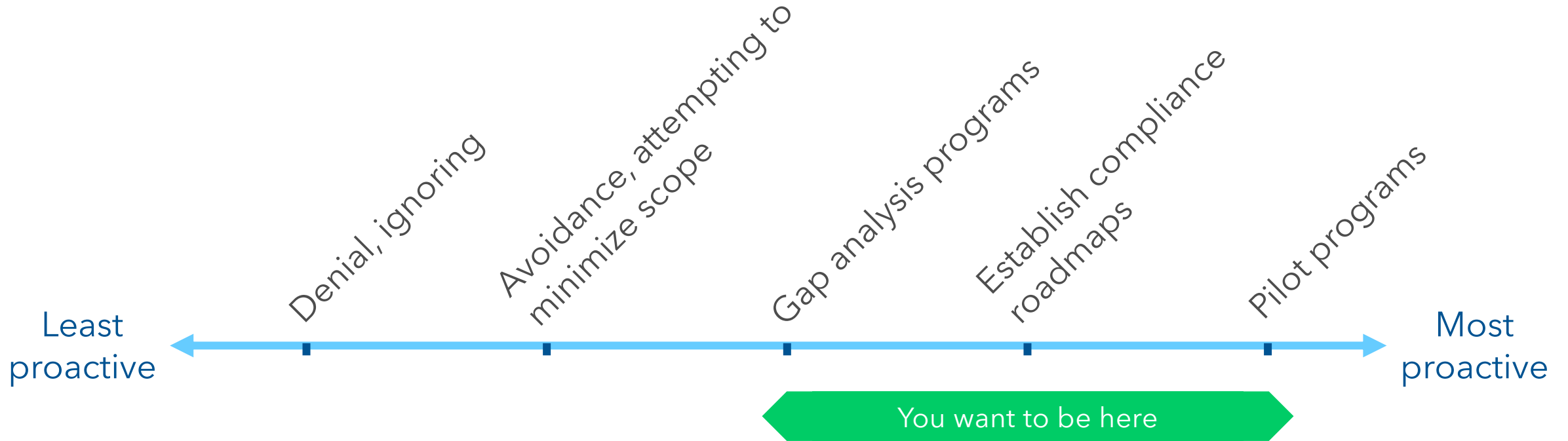
Decide how to demonstrate conformity

→ **Annex VIII (most companies will pick self-declaration)**

Analyze and close gaps:

- Security development lifecycle → Annex I Part I (1)
- Product security features → Annex I Part I (2)
- Vulnerability handling → Annex I Part II
- User documentation → Annex II
- Technical documentation → Annex VII

Companies are reacting across the spectrum



Topics for today

- 1 What CRA means for developers
- 2 Experience based on RED DA
- 3 Other things that I have seen
- 4 Q&A

1

What CRA means for developers

CRA forces insecure products off the EU market through mandatory updates and transparency

Who: The EU (Regulation (EU) 2024/2847)

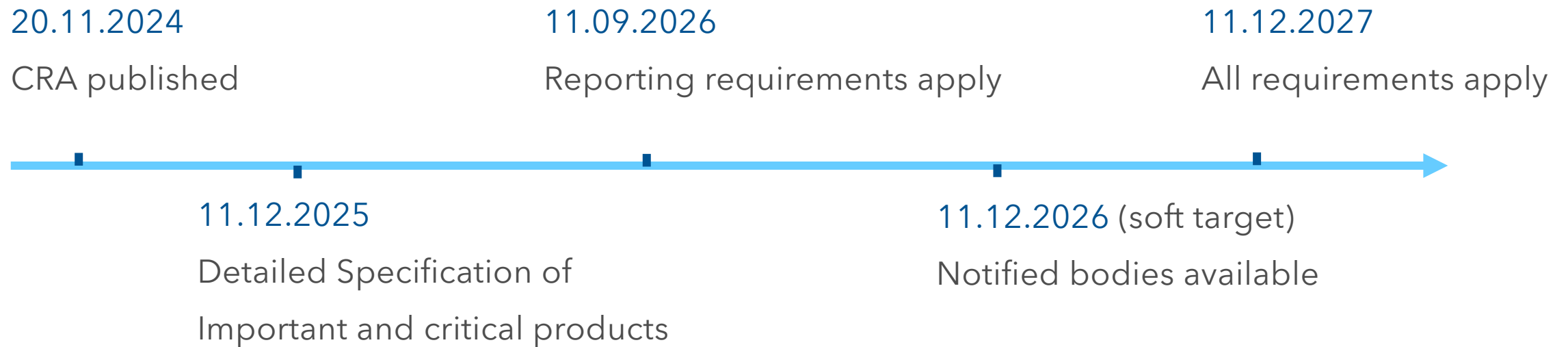
What: Security requirements for all “products with digital elements” sold in EU
→ In practice: all products that exchange data in some way
Exemption for MDR & IVDR devices

How:

1. Product requirements	}	For units sold after 11.12.2027
2. Support & vulnerability management requirements		
3. Process & documentation requirements		
4. Reporting requirements	}	From 11.09.2026, for all units

Fines: Up to 15'000'000 EUR or 2.5% of global turnover (whichever is higher)

The main deadline for the CRA is **11.12.2027**



Product = unit (~serial number)

Product != series (~model number)

First time “made available on the market”

Free products also in scope!



**All products placed on the EU market
after 11.12.2027 must be fully CRA
compliant.**

→ Existing designs must be retrofitted, but no external stock recalls needed

⚠ “substantial modifications” might trigger need for compliance

Products “with digital elements” that communicate with other devices or networks

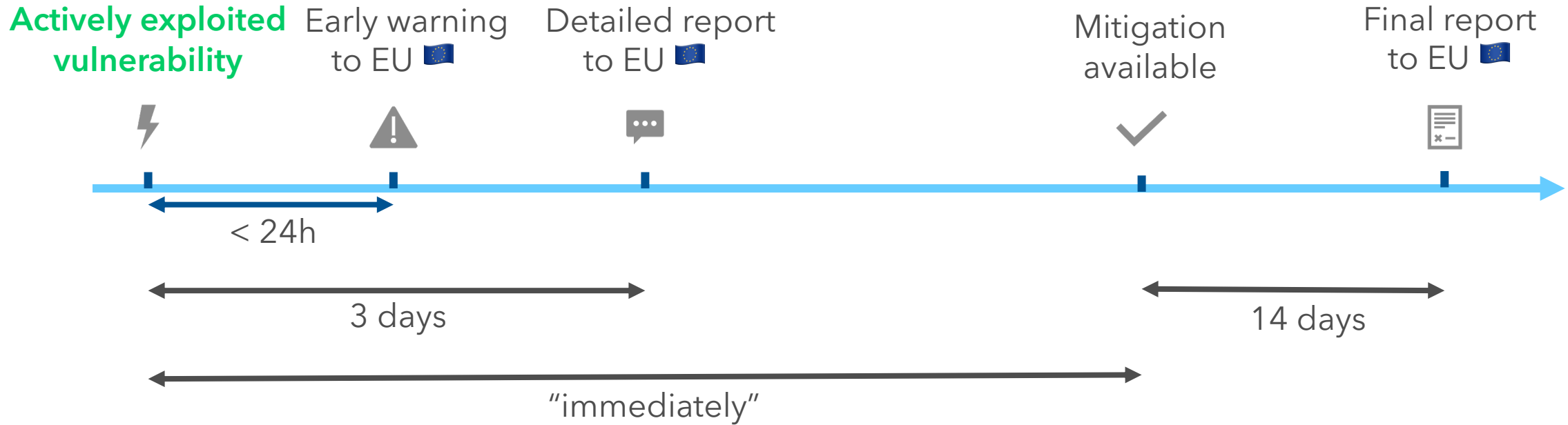
Date of sales is not relevant!

All products within the CRA's scope must comply with reporting requirements after 11.09.2026.

Does **not** include SW updates, recalls, vulnerability monitoring, ...

ACTION

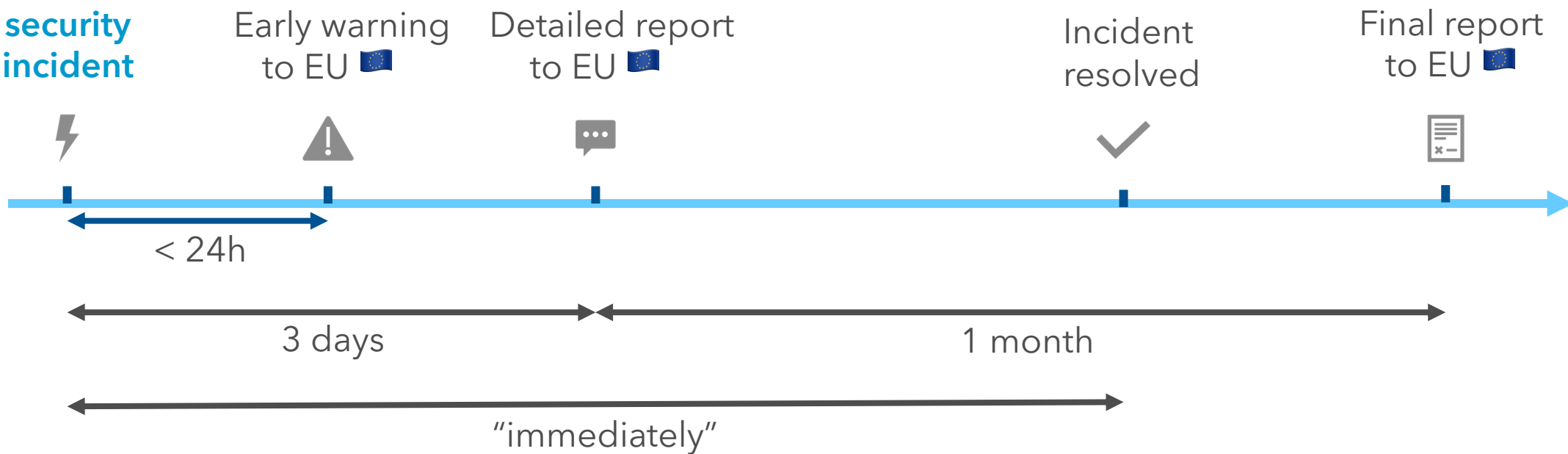
Companies must report active exploits within 24h



Reporting happens through "Single Reporting Platform" to ENISA and member state CSIRT
+ (affected) **users** must be informed

Companies must report severe security incidents within 24h

Severe security incident



Security development lifecycle is a must-have under CRA

Products must be
“designed, developed, and produced”
with cybersecurity in mind.

In (perhaps) familiar terms:

The CRA includes both IEC [62443-4-2](#), and IEC [62443-4-1](#)-style requirements.

All this is very similar to OWASP SAMM

CRA mandates products to be secure by default

This is enforced through [14 essential requirements](#) for products

No known exploitable
vulnerabilities

Protect product
availability (DoS)

Minimize data
processing

[Access control](#) & security
monitoring

Support (automatic)
[updates](#)

Protect other devices &
networks

[Protect](#) confidentiality and
integrity of [data](#)

Secure-by-default
configuration

And more ...

Example: Compliance Tracking

Sample Template for CRA Compliance Tracking for Product Cybersecurity Requirements

CRA Requirement	Description	Status	Evidence/Link	Owner	Confirmed Date
Annex I Part I (1)	Security development lifecycle evidence (DevSecOps)				
Annex I Part I (2) (a)	No known exploitable vulnerabilities on release				
Annex I Part I (2) (b)	Security by default and reset				
Annex I Part I (2) (c)	Security update mechanism				
Annex I Part I (2) (d)	Access control and reporting				
Annex I Part I (2) (e)	Data confidentiality				
Annex I Part I (2) (f)	Data integrity and corruption alerting				
Annex I Part I (2) (g)	Data minimization				
Annex I Part I (2) (h)	Availability and resilience				
Annex I Part I (2) (i)	Minimize impact on other devices or services				
Annex I Part I (2) (j)	Limit attack surface				
Annex I Part I (2) (k)	Reduce the impact of security incidents with mitigation techniques				
Annex I Part I (2) (l)	Logging and monitoring of security events with an opt-out mechanism				
Annex I Part I (2) (m)	Secure deletion of data and settings, with secure transfer when feasible				

CRA requires proactive vulnerability management

Software bill of materials
(SBOM)

Security test and
reviews

Public vulnerability
disclosure

Responsible disclosure policy

Single point of contact for
vulnerability notifications

Effective update distribution
mechanisms

Inform component suppliers
about vulnerabilities & share
patches

Due diligence for third-
party components

Companies need to prepare adequate documentation

Information and Instructions to the User (User-facing)

Allow users (& integrators) to

- Securely operate product
- Make security-conscious (purchase) decisions

Technical Documentation (Internal, for authorities)

Document processes & results

- Serves as paper trail
- Can be requested by EU

CRA mandates security product **instructions for users**

Single point of contact for vulnerabilities

Intended purpose & security properties of the product

Circumstances which may lead to security risks

Type of technical support provided & **end of the support period**

How to **securely (de)commission & use** the product

How modifications can affect data security

How to install **updates**

How to disable automatic security updates

Information for **integrators**

ACTION

CRA mandates **technical documentation** containing more detailed information **for authorities**

User-facing documentation

Software bill of materials (**SBOM**)

Design and **architecture info**

Info on vulnerability handling process

Info on production process

The risk assessment

Motivation for support period duration

List of applied (harmonized) standards and specifications

Test reports

ACTION

Products must be **kept compliant during** a predefined **support period**

The support period should

- “reflect the length of time during which the product is expected to be use”
- be **at least 5 years** (except for short-lived products)
- commission can set minimum support periods for specific products

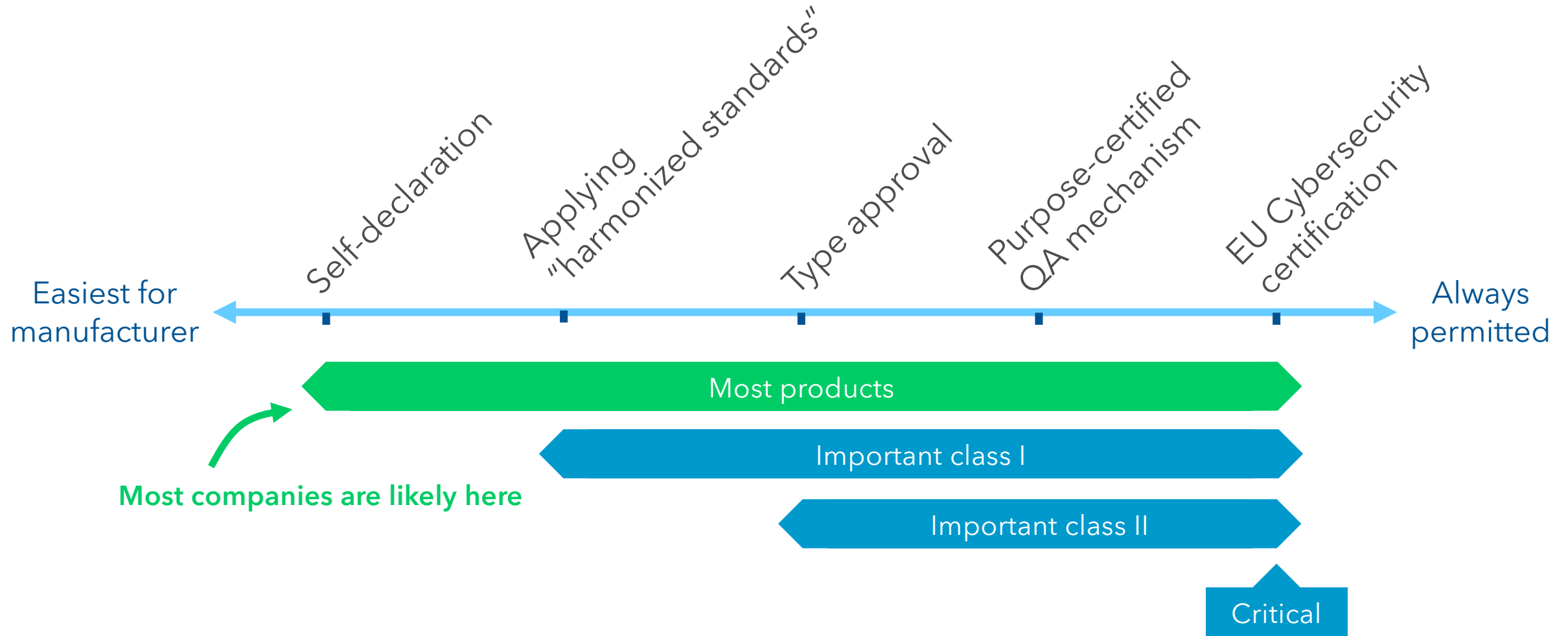
Security updates

- **separated** from functionality updates (if possible)
- must be **free of charge** (except tailor-made products)



**Non-compliance
may lead to forced recalls**

Compliance is typically proven by **self-declaration** through CE marking & **EU DoC** (Declaration of Conformity)



Self declaration is based around the risk assessment

1.

Perform
risk assessment

2.

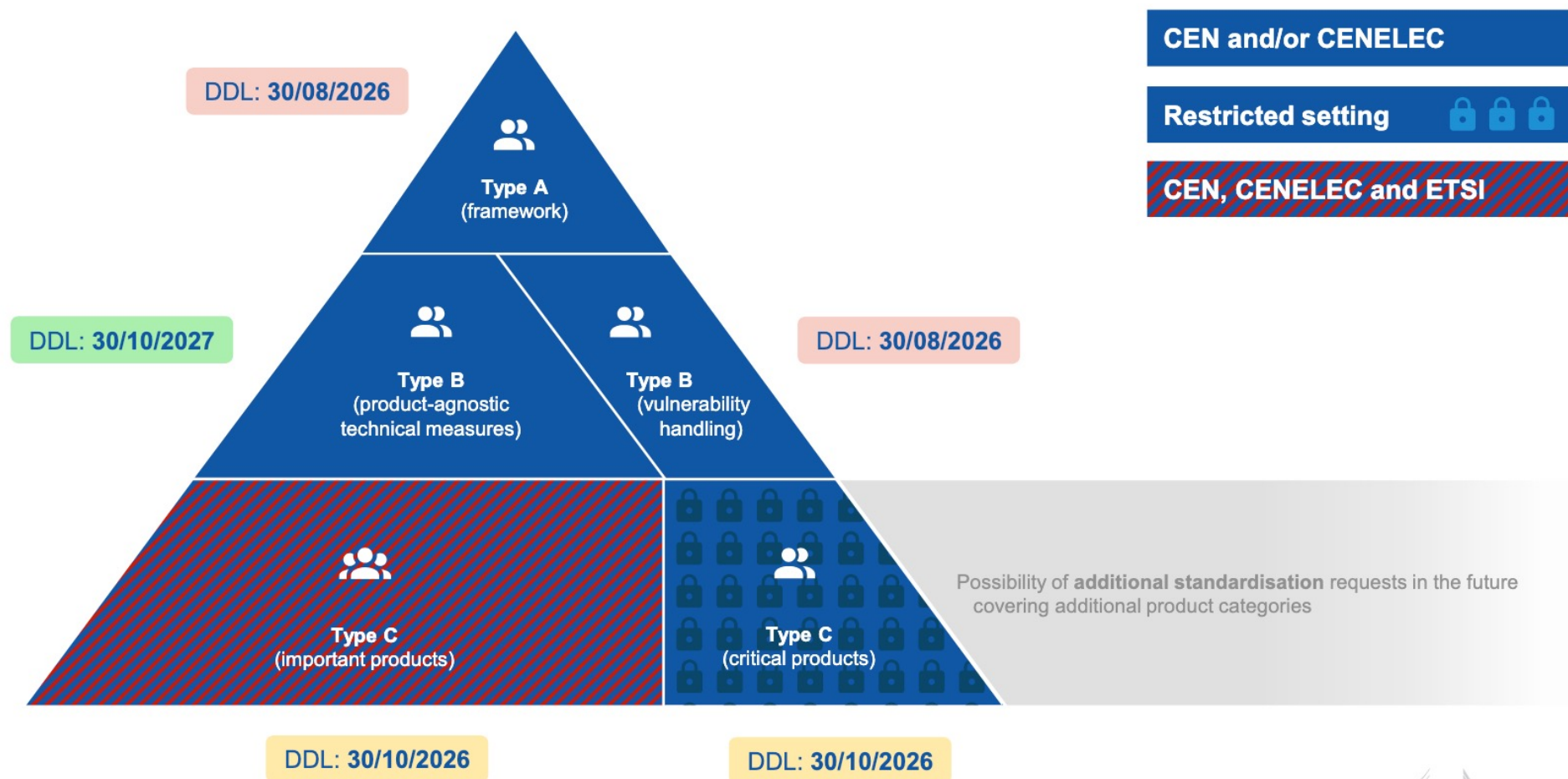
Demonstrate that
essential requirements are fulfilled
& compile technical documentation

3.

Draw up DoC
And add CE mark
to product

➔ Manufacturer must proof that essential requirements are fulfilled!

Draft standardisation request in a nutshell



[Slides from the 1st meeting of the CRA Expert Group]

Harmonized standards are a shortcut to CRA conformity

1.

Perform
risk assessment

2.

Apply harmonized standards to product
& compile technical documentation

3.

Draw up DoC
and add CE mark
to product

2

Experience based on RED DA

Harmonized standards might require us to do three types of assessments

Assessment Type	What It Checks	Example
Conceptual Assessment	Does the security reasoning reasonable?	A network interface has no security mechanism because it is disabled in production
Functional Completeness	Is everything accounted for?	Using a network scanner to verify all external interfaces are listed
Functional Sufficiency	Does the security mechanism work?	Try to log in with an incorrect password

Example: Update mechanism (SUM-1)

Conceptual assessment helps you decide whether a requirement applies

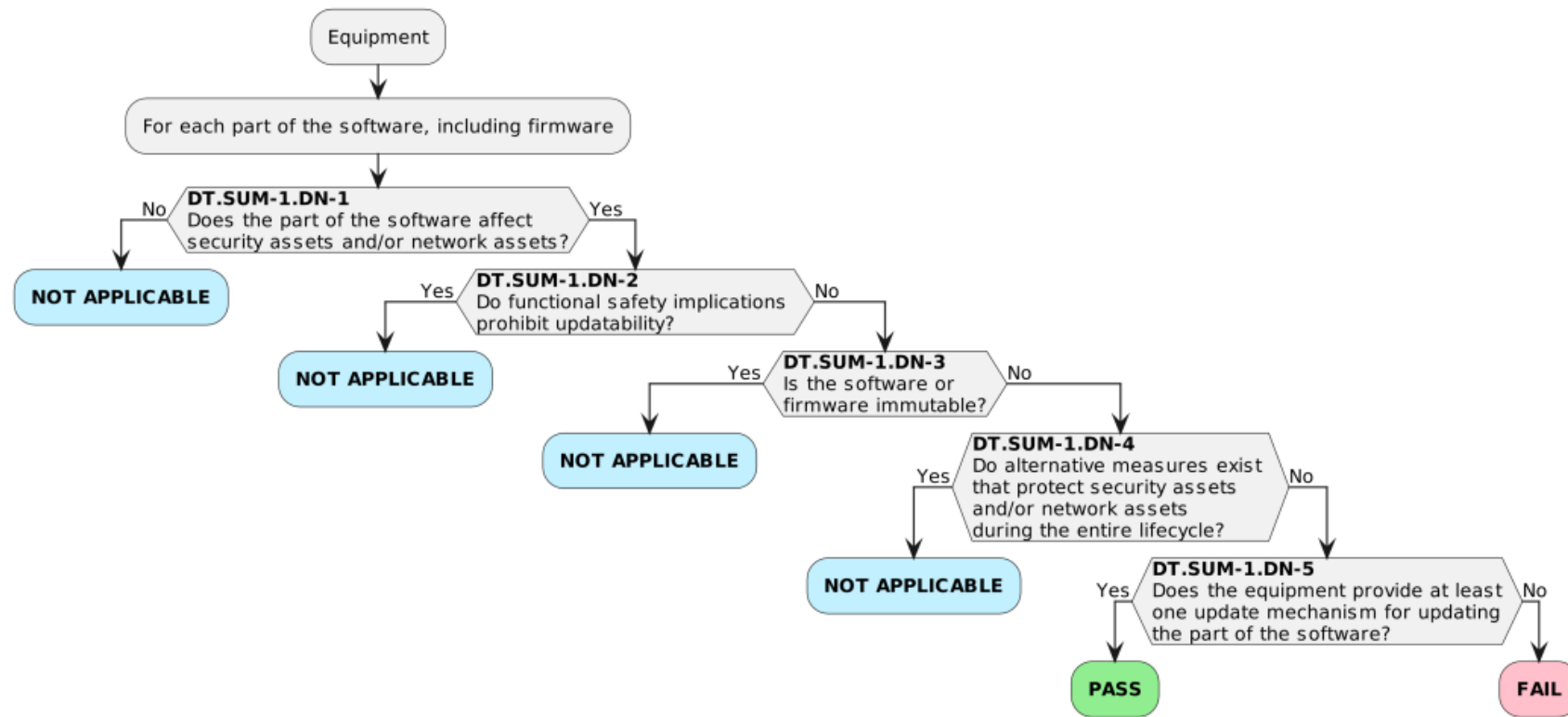


Figure 11 — Decision Tree for requirement SUM-1

Example: Secure update (SUM-2)

Conceptual assessment helps you decide whether a requirement applies

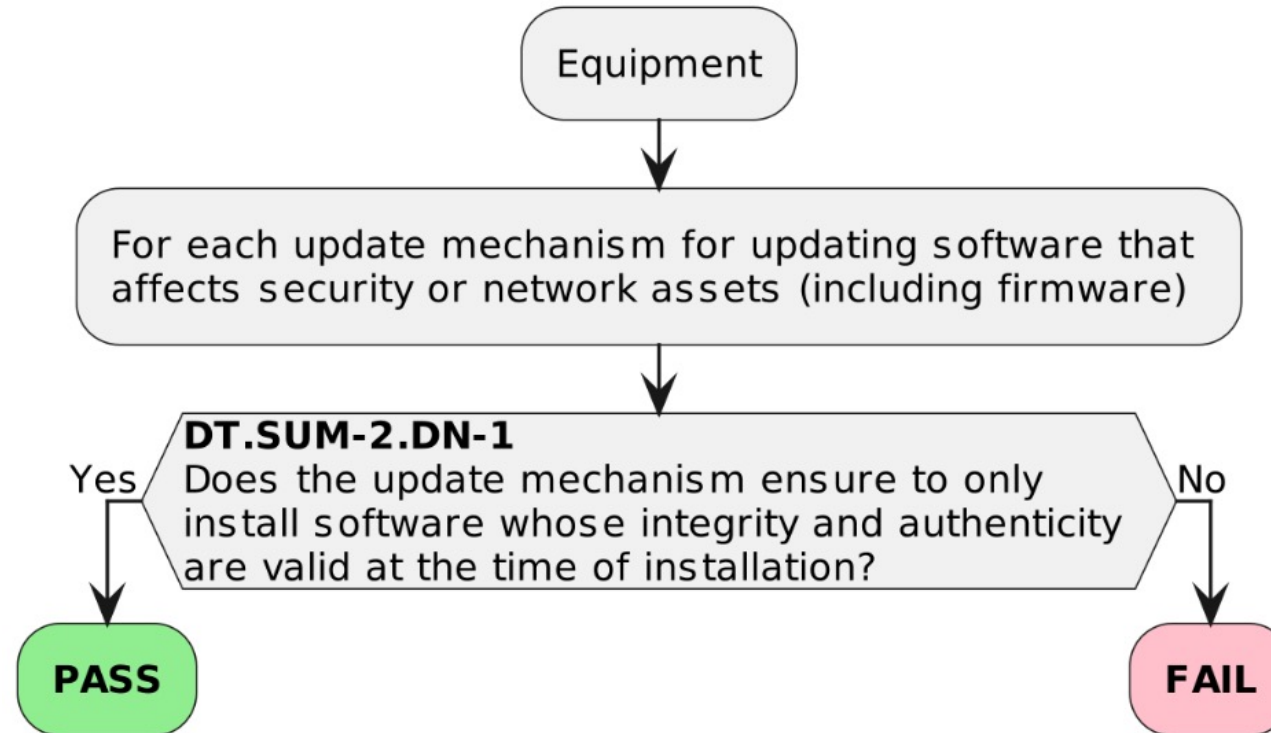
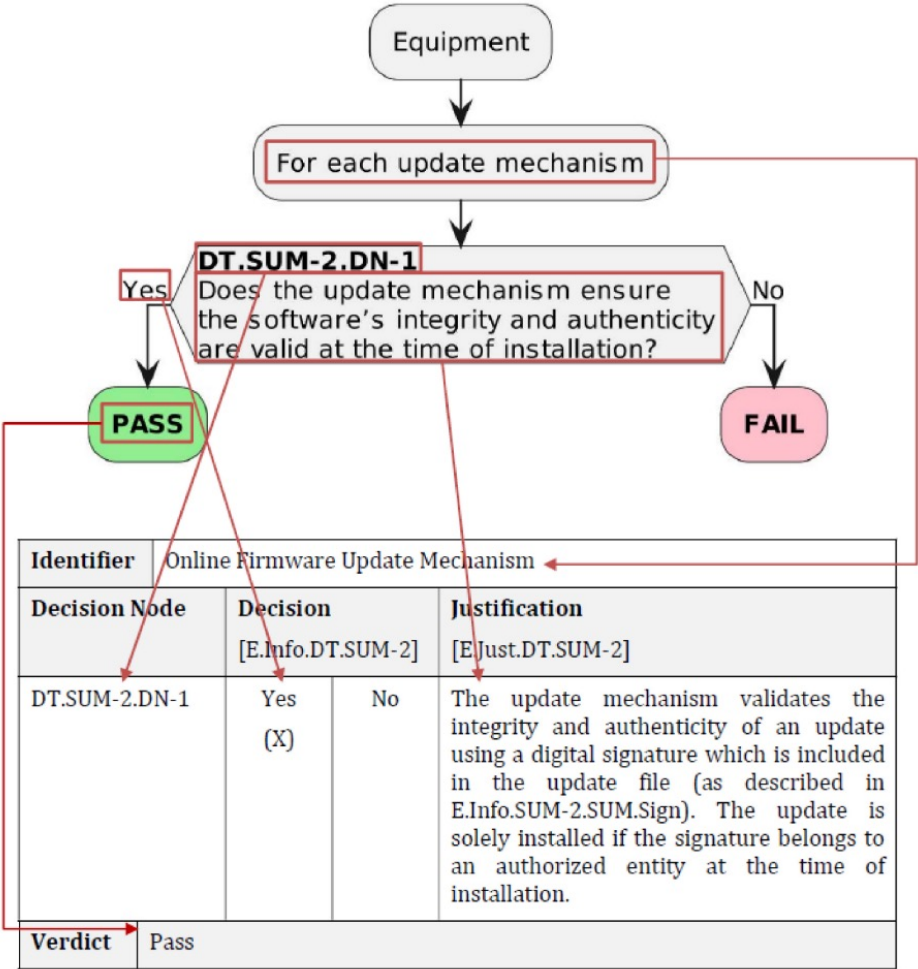


Figure 12 — Decision Tree for requirement SUM-2

It only counts if you document it



3

Other things that I have seen

4

Q&A

Takeaway cheat sheet: what companies need to do for CRA

List products affected by CRA:

- Regular products → Article 3
- Important products → Annex III
- Critical products → Annex IV

Decide how to demonstrate conformity

→ **Annex VIII (most companies will pick self-declaration)**

Analyze and close gaps:

- Security development lifecycle → Annex I Part I (1)
- Product security features → Annex I Part I (2)
- Vulnerability handling → Annex I Part II
- User documentation → Annex II
- Technical documentation → Annex VII